

RecallGuard: handbook core design

Revision: 2026-09-26. Status: local core implementation; public deployment pending.

Problem and boundaries

Preserve selected user facts across sessions without mixing owners, retaining expired facts, or replaying unlimited history. The browser/API is untrusted. API keys map to user identities on the server. Storage administration and the host running Ollama are trusted.

Components

Flask app factory validates HTTP requests and authenticates users. MemoryService applies consent, privacy, admission and write policies. MemoryStore enforces ownership and lifecycle in Chroma. One normalized MiniLM encoder is shared by storage and retrieval. Ranking combines similarity, importance, confidence and recency. ContextBuilder bounds the rendered prompt. LocalLLM invokes Ollama with a timeout and output limit. ReflectionEngine removes expired/low-confidence records and exact duplicates.

Write path

Validate object/types/limits; require consent for explicit storage; reject supported sensitive patterns before embedding. Exact duplicate content/type is reused within the same owner. Save text, vector, source reference, UTC timestamps, version and expiration. Explicit correction replaces text/vector, increments version, and preserves expiry. Chat does not automatically resolve contradictions.

Read and context path

Resolve owner from credentials; filter active owned IDs before candidate retrieval. Retrieve at most 100 candidates. Accept sufficient similarity or complete non-stopword query-term coverage. Apply requested confidence/type filters, then rank and truncate. Serialize memory as untrusted data. Bound complete rendered content using UTF-8 units plus 160 envelope units and 128 output units within the configured 1000-unit budget.

Lifecycle and privacy

New records retain at most seven days. Expired records are immediately hidden on reads. A separate hourly worker or scheduled one-shot removes expired/legacy-deleted records. DELETE synchronously removes records through Chroma; no forensic or external-backup erasure claim. Legacy missing-expiry records are not silently migrated.

Failures and operations

Invalid input returns 400; unauthorized 401; absent/foreign records 404; oversized body 413; dependencies 503. Generation may fail after a successful write, so the response reports committed write decisions. Operational logs omit message content and raw exceptions. One process is supported for write locking. Public identity, rate limits, TLS, cloud migration and recovery evidence are deployment gates.

Evaluation and limits

Use temporary real-database regression tests, a reusable contract with injected faults, fixed baseline comparisons with lexical and MiniLM embeddings, and a live Ollama smoke. The 16 scenarios are development data. Independent verification remains outstanding. Scale is bounded by per-user active-ID scans; tokenizer matching, calibrated scores and broad adversarial evaluation remain future work.